

(http://connect.qq.com/widget/screenshot/eq/index.html?url=https%3A%2F%2Fxt.hreatlab.co.uk%2Fno-dev%4%2Fb%4%2Farticle%3Fhtml%3Ftitle%3E890%3E5%3EBAEAEE

IP、域名、文件HASH(MD5/SHA1/SHA256)、URL、邮箱

6%
A
D%
A
5%
E
5%
9
C%
A
8%
E
7%
B
A%
B
F%
E
6%
8
A%
A
5%
E
5%
9
1%
8
A%
E
3%
8
0%
9
1%
26l
dq
u
o%
3
B%
E
9%
9
A%
9
4%
E
7%
A
6%
B
B%
E
7%
B
D%
9
1%
E
7%
B
B%
9
C%
E
6%
9
4%
B
B%
E
5%
a

o
7%
B
B%
26r
dq
u
o%
3
B%
E
4%
B
8%
9
3%
E
9%
A
2%
9
8% (htt
E p://
7% ser
A vic
0% e.w
9 eib
4% o.c
E o
7% m/
A sha
9% re/
B sha
6% re.
E ph
6% p?
8 url
A% =h
A ttp
5% s%
E 3
5% A%
9 2
1% F%
8 2F
A% x.t
20- hre
%2 atb
0% oo
E k.c
5% n%
B 2F
E% no
A de
E% v
E 4%
6% 2Fv
A b
D% 4%
A 2Fa
5% rtic
E l
5% e%
9 3Ft
C% hre
A atl
8% nfo
E l
7% D%
B 3D
A% 30
BF 00
X% &ti
E tle

IP、域名、文件HASH(MD5/SHA1/SHA256)、URL、邮箱

6% =%
8 E
3% 3%
8 8
5% 0%
E 9
6% 0%
8 E
A% 5%
A B
5% E%
E A
7% E%
A E
4% 6%
B A
E% D%
E A
5% 5%
8 E
C% 5%
BA 9
&s C%
our A
ce 8%
=% E
E 7%
3% B
8 A%
0% B
9 F%
0% E
E 6%
5% 8
B A%
E% A
A 5%
E% E
E 5%
6% 9
A 1%
D% 8
A A%
5% E
E 3%
5% 8
9 0%
C% 9
A 1%
8% 26l
E dq
7% u
B o%
A% 3
B B%
F% E
E 9%
6% 9
8 A%
A% 9
A 4%
5% E
E 7%
5% A
9 6%
1% B
8 B%
A% E
E 7%
3% B
8 D%
0% 9
9 1%
1% E

1 %	E
E	7%
2%	B
8	B%
0%	9
9	C%
C%	E
E	6%
9%	9
9	4%
A%	B
9	B%
4%	E
E	5%
7%	8
A	7%
6%	B
B	B%
B%	26r
E	dq
7%	u
B	o%
D%	3
9	B%
1%	E
E	4%
7%	B
B	8%
B%	9
9	3%
C%	E
E	9%
6%	A
9	2%
4%	9
B	8%
B%	E
E	7%
5%	A
8	0%
7%	9
B	4%
B%	E
E	7%
2%	A
8	9%
0%	B
9	6%
D%	E
E	6%
4%	8
B	A%
8%	A
9	5%
3%	E
E	5%
9%	9
A	1%
2%	8
9	A%
8%	20-
E	%2
7%	0%
A	E
0%	5%
9	B
4%	E%
E	A
7%	E%
A	E
9%	6%
B	A
6%	D%
E	A

6% 5%
8 E
A% 5%
A 9
5% C%
E A
5% 8%
9 E
1% 7%
8 B
A% A%
20- BF
%2 X%
0% E
E 6%
6% 8
8 3%
3% 8
8 5%
5% E
E 6%
6% 8
8 A%
A% A
A 5%
5% E
E 7%
8% A
A 4%
F% B
A E%
6% E
E 5%
6% 8
8 C%
3% BA
85 &p
&d ic=
esc htt
=& p
pic s%
s= 3
htt A%
p 2
s% F%
3 2F
A% x.t
2 hre
F% atb
2F oo
x.t k.c
hre n%
atb 2Fs
oo tati
k.c c%
n% 2Fi
2Fs m
tati g%
c% 2F2
2Fi d_c
m od
g% e.jp
2F2 g&
d_c ap
od pk
e.jp ey
g) =)

【微步在线报告】“隔离网络攻击”专题研究报告

首页 (/)

IP、域名、文件HASH(MD5/SHA1/SHA256)、URL、邮箱

本篇报告较长，篇幅所限，本文仅为部分内容。

扫描文末二维码，并关注【微步在线研究响应中心】公众号。

公众号内回复关键词“隔离网络”，可查看完整报告。

1.概述

威胁情报（Threat Intelligence），也被称作安全情报（Security Intelligence）、安全威胁情报（Security Threat Intelligence），是通过大数据、分布式系统或其他特定收集方式获取，包括漏洞、威胁、特征、行为等一系列证据的知识集合及可操作性建议，可还原已发生的和预测未来可能发生的网络攻击，为用户决策提供参考依据，帮助用户避免或减少网络攻击带来的损失。该定义是一种对威胁情报较为通俗易懂的解释。从2014年开始，威胁情报逐渐成为网络安全领域的热点。在2018-2019年，采用基于ATT&CK矩阵模型来指导建设威胁情报系统的方法被业内广泛认可。但当前阶段，实际落地到客户现场的威胁检测服务，其实只是应用了非常狭义的威胁情报（主要为基于哈希、域名、IP等元素的碰撞），除了情报数据的可靠性、丰富性、及时性等因素会严重影响用户体验之外，当前的威胁情报检测在针对某些特定类型攻击的场景下有着严重的短板，例如针对隔离网络的定向攻击。

微步情报局近期整合了当前捕获到的一些针对隔离网络的攻击事件以及历史上著名的Stuxnet蠕虫、Flame蠕虫等攻击事件，我们对其中的隔离网络攻击部分展开了深入分析，旨在剖析其攻击框架、梳理其特有的攻击指纹以及针对此类攻击的复盘思考。

2.背景

网络隔离，英文名为Network Isolation，主要是指把两个或两个以上可路由的网络（如：TCP/IP）通过不可路由的协议（如：IPX/SPX、NetBEUI等）进行数据交换而达到隔离目的。网络隔离技术的核心是物理隔离，并通过专用硬件和安全协议来确保两个链路层断开的网络能够实现数据信息在可信网络环境中进行交互、共享。

借助物理层面的网络隔离在理想情况下可以有效地阻断传统的基于网络路由可达的网络攻击、确保隔离内网的生产环境的安全稳定。当前建设隔离网络的主要单位传统制造业、化工行业、能源行业、军工行业等。然而隔离网络系统的建设注定着要牺牲网络数据交换的便捷性。为了解决实际生产环境中的数据交换需求，经常会出现一些“不得已”的违规操作，譬如搭建内网跳板机映射共享目录、使用可移动存储设备进行数据摆渡等，这些操作相当于间接打通一条与外网通信的隧道、破坏了物理隔离的完整性。除此之外，物理隔离环境会导致隔离内网环境的安全更新（漏洞补丁、病毒库等）滞后，各种基于指纹检测的安全设备检测能力也会大打折扣，一旦攻击方使用特殊技巧突破隔离网络，后果不堪设想。

借助移动存储设备摆渡实现对隔离网络的攻击是一项具有挑战性的任务。站在攻击方角度，攻击载荷的设计需要考虑众多问题：如何应对未知的隔离网环境；如何防止攻击组件的扩散（可移动存储设备并非完全用于隔离网络）；如何准确的进行USB摆渡信息交互（如果需要交互的话）；如何降低被发现的风险并且提升攻击成功率。

所以，在实际攻击案例中，针对隔离网络的定向攻击活动的幕后团伙往往是实力强大的国家级网军队伍。曾经轰动一时的Stuxnet（震网）攻击事件、Flame蠕虫、CIA（美国中央情报局）网络武器库Vault7、斯诺登披露的NSA（美国国家安全局）秘密武器COTTON-MOUTH、光盘感染组件HammerDrill以及今年5月曝光的Darkhotel组织的Ramsay隔离网突破组件等，这些都是针对隔离网络攻击的经典案例。

3.攻击事件回顾

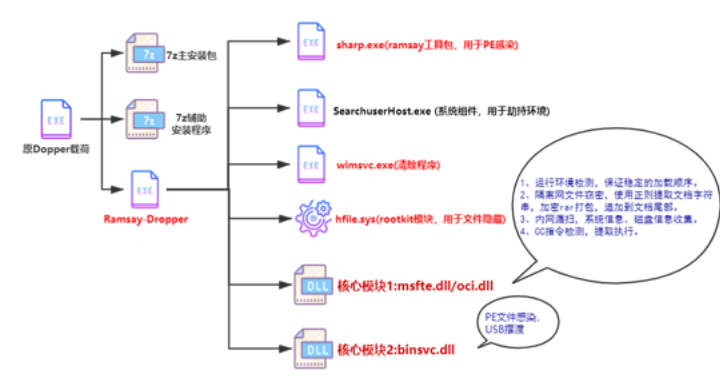
针对隔离网络的攻击事件 较常规攻击事件而言，存在其特有的攻击属性。其攻击目标主要为传统制造业、能源行业、化工行业、军工行业等；布局在隔离网络中的生产环境涵盖了目标单位最核心的设备资产，绝大多数的隔离网络环境中架设了生产相关的工控网络，基于此特定环境，攻击方的攻击目的包括窃取核心生产机密、工控设备攻击、隔离内网勒索等；隔离网络的物理分隔特性以及内部环境的复杂性对攻击方提出了巨大挑战，所以攻击方一般背景强大，有着功能强大的武器库储备，攻击侦察阶段会有足够的社工力量投入并且整个攻击过程持续时间较长。

3.1 DarkHotel Ramsay

3.1 Darkhotel-Ramsay

2020年5月，国外安全机构ESET发现了一款名为Ramsay的攻击组件，该组件具备隔离网络攻击能力，经关联分析，该组件为Darkhotel组织所有，至今已存在多个迭代版本。Ramsay组件为携带蠕虫模块的打包器程序，通过USB移动存储设备进行互联网主机与隔离网络主机之间的信息摆渡，最终实现内网渗透、文件窃密、恶意模块执行、shell执行等功能。

在互联网PC主机失陷之后，伪装成7z安装包的PE文件将会落地执行，Ramsay打包器程序在该过程中得以执行。Ramsay是一个基于模块化设计的复杂的蠕虫类木马，在确保预期的白利用侧加载环境以及借助rootkit模块实现的木马组件隐藏之后，其核心模块才会加载执行。核心模块有两个（根据PC环境选择释放适配32位/64位模块），一个用于PE文件感染，该模块会感染除系统盘之外（包括共享目录）的PE文件，感染后的PE文件与原7z打包器程序结构一致，然后设置与原PE相同的时间信息，该模块通过感染USB可存储设备中的PE文件进行摆渡进入隔离网络；另一个模块用于内网渗透以及信息收集，该模块会收集隔离网主机系统信息、磁盘信息，加密存储为本地日志，通过永恒之蓝系列payload扫描局域网各主机漏洞进行横向渗透，通过正则匹配模式收集PC上Office文件以及txt文件的内容文本信息、并加密压缩存储，待合适时机通过U盘等设备以文件追加方式带出隔离网络，该模块还会检测U盘设备中感染文件是否携带C&C下发指令以及相应资源，如存在则解析执行。



提取出原打包器程序释放中间件信息罗列如下：

Table 1

模块名称	功能介绍
oshudqzidg.exe	7z安装包
Evbhmkgdsl.exe	7z辅助安装程序
Sharp.exe	Ramsay工具包，用于PE感染时提供打包资源
SearchuserHost.exe	系统组件，用于劫持环境
wimsvc.exe	清除程序、运行bat删除组件模块
hfile.sys	rootkit模块，用于文件隐藏
msfte.dll/oci.dll	内网漏扫、文件窃密、CC指令交互
binsvc.dll(存在32位和64位)	当前PC及共享网络中PE（exe）文件感染

此次攻击依赖的两个核心组件为bindsvc.exe和msfte.dll。其中前者完成PE文件感染、后者实现隔离网内部的信息传输。完整攻击流程中还涉及其他由鱼叉邮件释放的C&C交互模块。在USB摆渡阶段及内网窃密、渗透部分并没有直接的C&C交互。通过对已获取的载荷分析，我们无法知悉真实攻击事件中受害者的实际失陷情况，隔离网络攻击成功与否暂时未知。

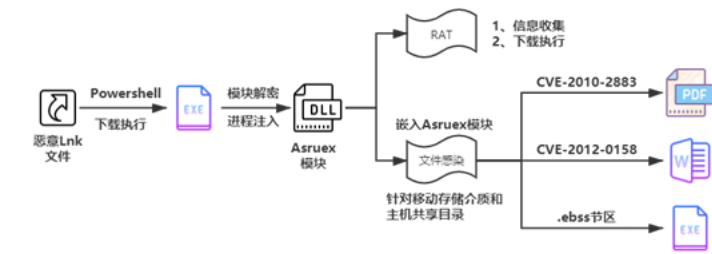
客观评价该隔离网攻击模块，它存在明显的优缺点。优点：该组件整体框架较为健壮，各模块对执行上下文均存在完整检测，以确保在特定环境下各组件模块的协同；基于正则匹配提取office文档中字符串信息然后加密压缩、以文件追加方式借助USB摆渡带出隔离网络，这一过程隐匿性较好；通过感染移动介质的office open xml/rtf/pdf文件实现将C&C下发内容带入隔离网络，在隔离网络中通过特定字符串标记提取运行，然后去掉感染内容还原文件，该C&C信息交互部分设计较为巧妙。缺点：部分模块存在不少的死循环逻辑，该缺陷会加大可疑进程暴露几率；EXE文件感染模块设计较为笼统，除了USB存储设备、共享文件，其他非系统盘中的EXE文件均为被感染。

3.2 DarkHotel-Asruex

X 首页 (/)

IP、域名、文件HASH(MD5/SHA1/SHA256)、URL、邮箱

Asruex是一款附带蠕虫感染能力的后门类型木马，该木马最早于2015年因被关联到Darkhotel APT组织而被公众熟悉，Darkhotel组织在针对中日国家特定从业人员的定向攻击中曾使用了该木马。Asruex最开始被披露时，人们关注的重点为它的PC主机信息收集功能和后门执行功能，它的文件感染能力并没有深入分析。直到后续趋势科技的恶意代码研究人员在总结分析Asruex木马时，才发现其强大的蠕虫感染能力。通过对感染模块的深入分析，证实了Asruex木马具备借助USB摆渡实现人力传播的能力。



文件感染模块主要针对移动存储介质和主机共享目录中pdf、office、exe文件。文档类型感染过程使用了稳定的Nday漏洞利用技术：针对pdf文件的感染使用了经典的栈溢出漏洞CVE-2010-2883，针对word文件的感染使用了利用技术简单稳定的栈溢出漏洞CVE-2012-0158，用户在未安装相应漏洞补丁的机器上打开文档时，即触发相应漏洞、解密内嵌的PE模块并通过起cmd.exe或rundll32.exe进程加载执行，整个恶意代码执行过程对用户而言是无感知的，展现给用户的只是用户熟悉并知道合法来源的文档内容界面。EXE文件的感染是通过添加名为.ebss的新节区、写入加密的Asruex数据、然后在.text段加入解密执行代码来实现的。

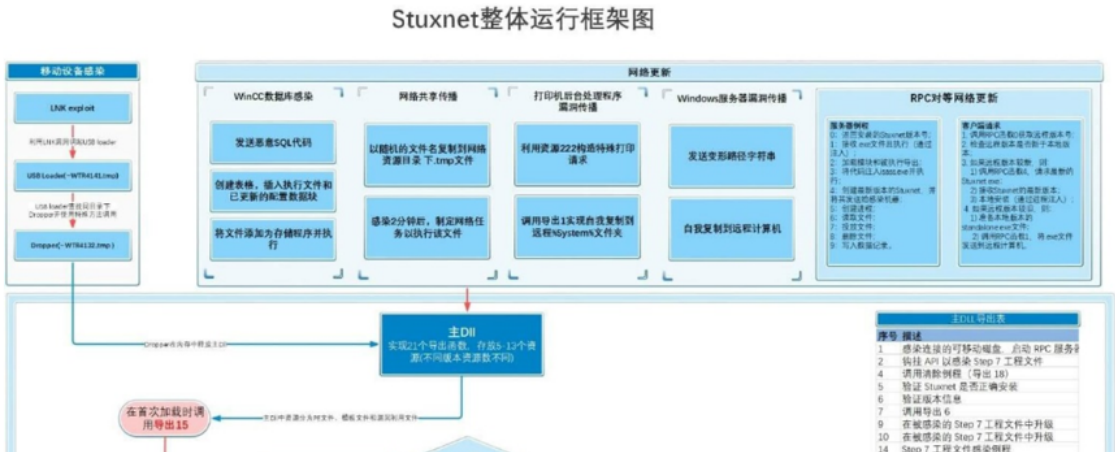
到现在为止，我们能确定的只是Asruex木马具备信息收集、后门执行、USB存储设备中文件感染的能力。其对于隔离网络环境的攻击只是我们的猜测，如果比对严格的隔离网攻击事件的话，其缺少明显的环境探测环节以及可能会涉及的摆渡信息交互环节。当然该木马的后门功能部分可以在互联网PC机器上通过C&C端下发组件去完善这些缺失的功能，所以基于已有的分析研究我们可以初步判定Darkhotel组织的Asruex木马具备初步的隔离网攻击结构。

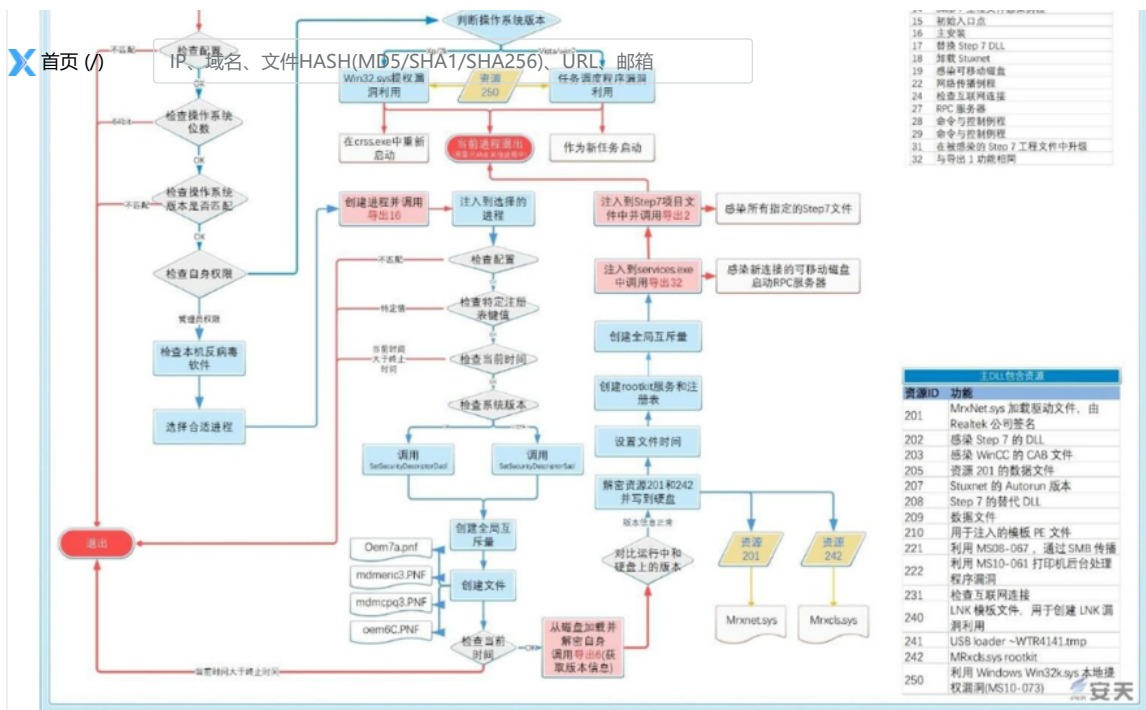
3.3 Stuxnet

如果说上述提到的攻击事件只是初步具备隔离网攻击能力，那么震网攻击事件中的Stuxnet蠕虫绝对是教科书级别的专业隔离网络攻击武器。Stuxnet蠕虫于2010年被国内外多家安全机构披露，虽然至今已过去十年时间，但是其放在今天依然是核弹级别的网络武器。

2010年6月，“震网”病毒首次被发现，它被称为有史以来最复杂的网络武器。美方所发起的该起攻击事件是一起出于军事打击的核建设设施摧毁的攻击活动。震网活动经过长期规划准备和入侵潜伏作业，借助高度复杂的恶意代码和多个零日漏洞作为攻击武器，以铀离心机为攻击目标，以造成超导导致离心机批量损坏和改变离心机转速导致轴无法满足武器要求为致效机理，最终阻断了军事敌对国伊朗的核武器研发建设。这也是首起被披露的借助网络武器实施隔离网络工控设备攻击而且攻击成功的事件。

震网事件中Stuxnet系列蠕虫涉及多种功能框架、多个操作系统和应用程序以及IOC设备等相关的0day利用技术、多个功能模块，其整体运行框架流程图借用友商研究报告中的原图，如下所示。





Stuxnet蠕虫的渗透过程分为两步, 借助USB存储设备摆渡从互联网PC进入隔离网络和隔离网内部横向渗透传播。USB摆渡过程使用了Lnk漏洞或autorun.inf自启配置文件, 当USB设备插入隔离网PC机器, 如存在autorun.inf文件则会自动运行 (加载U盘中的隐藏的Stuxnet木马), Lnk文件漏洞是通过Windows文件管理器第一次解析Lnk文件时的逻辑缺陷使之加载Lnk文件目录的恶意DII模块, 该过程在USB设备插入PC时触发、无需其他用户交互操作。内网横向传播过程, Stuxnet木马会通过局域网共享目录传播自身, 通过感染WinCC数据库进行间接传播, 或者借助多个0day利用模块 (如打印机后台程序漏洞、Windows服务器漏洞等) 实现横向传播。Stuxnet进入隔离网络传播至内网各主机之后, 会启用RPC服务进行该局域网监听, 同步最新的Stuxnet木马, 探测到控制工控网络的WinCC管理程序之后, 即发动针对核反应设备的攻击行为。

Stuxnet蠕虫基于模块化设计, 核心payload资源通过PE文件资源节区嵌入, 各模块功能说明如下。

Table 2

资源ID	功能
201	MRxNet.sys加载驱动, Realtek签名
202	感染Step 7的DLL
203	感染WinCC的CAB文件
205	资源201的数据文件
207	震网的自动运行版本
208	Step 7 替换DLL
209	数据文件
210	用来注入的PE模板文件
221	通过SMB传播的CVE-2008-4250利用
222	CVE-2010-2729打印机后台处理程序漏洞利用
231	网络连接检查
240	用来创建LNK利用的LNK模板文件
241	USB设备被加载的DLL, ~WTR4141.tmp
242	Mrxcls.sys
250	CVE-2010-2743本地提权漏洞利用

在整个攻击过程中使用的0day/nday漏洞列出如下。

Table 2

Table 3

漏洞编号	IP、域名、文件HASH(MD5/SHA1/SHA256)、URL、邮箱	漏洞说明
CVE-2008-4250		RPC漏洞，可实现远程任意代码
CVE-2009-1126		本地提权漏洞
CVE-2010-2568		Lnk快捷方式漏洞，可实现任意Dll加载
CVE-2010-2729		打印机后台程序漏洞，任意代码执行
CVE-2010-2743		借助Win32k实现本地提权
CVE-2010-3888		借助Win32k实现本地提权
CVE-2012-3015		不安全库加载，用于加载Step7

震网事件让人震撼的地方主要有两点：高复杂度、高强度的攻击武器投入，投入数个0day漏洞用于突破本来安全程度就不够高的隔离网络环境；进入隔离网络后的Stuxnet蠕虫拥有固定的执行流程（无C&C交互）、该过程是无法修改的，而目标隔离网络环境同样高度复杂，Stuxnet蠕虫最终依然能凭借高强度的自适应能力穿透未知的隔离网环境摧毁核反应设备完成攻击目的，这种网络攻击能力是让人细思极恐的。

3.4 Cycldex-USBulprit

USBulprit木马由卡巴斯基恶意代码分析团队在今年6月份披露，该木马为Cycldek APT组织所有，并且在2018年的定向攻击事件中投入使用。准确来讲，该木马是一个借助USB移动存储设备进行不同PC机器之间数据交互的功能组件（动态链接库Dll），通过对其进行功能分析能够确认该木马具备隔离网络数据交互、信息收集的能力。

USBulprit木马采用无文件攻击技术启用，由一个免杀能力较好的加载器模块加载指定目录下的加密二进制文件，然后内存解密装载执行。内存PE模块通过导出函数实现相应功能，其符号名称可读性较好。

Name	Address	Ordinal
CUSB::CUSB(void)	10002600	1
CUSB::operator=(CUSB const &)	10001000	2
CUSB::Disk2USB(wchar_t *,wchar_t *)	10003CB0	3
CUSB::FreeRar(void)	10002CC0	4
CUSB::GetPath(void)	10003160	5
CUSB::REGRUN(void)	10002DC0	6
CUSB::RegHideFile(void)	10003020	7
CUSB::RegHideFileExt(void)	10002F70	8
CUSB::RunHide(wchar_t *)	10002EC0	9
CUSB::TraverseFolder(wchar_t *,int)	10004020	10
CUSB::USB2Disk(wchar_t *,wchar_t *)	10003330	11
CUSB::USBFindFile(wchar_t *)	10003500	12
CUSB::openexp(wchar_t *)	100030D0	13
CUSB::startwork(void)	10002620	14
DllEntryPoint	10005B68	[main entry]

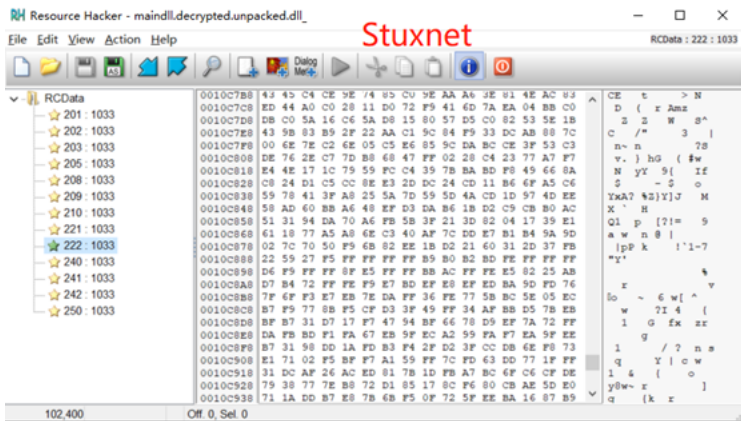
经逆向分析，列出导出函数功能说明如下。

Table 4

export	Introduction
CUSB::CUSB(void)	初始化类变量，"abcd!@#\$"
CUSB::operator=(CUSB const &)	用于拷贝构造的运算符重载
CUSB::Disk2USB(wchar_t ,wchar_t)	磁盘文件拷贝至USB存储设备
CUSB::FreeRar(void)	解压缩
CUSB::GetPath(void)	拼接各种所需路径
CUSB::REGRUN(void)	设置注册器自启驻留
CUSB::RegHideFile(void)	设置文件隐藏属性
CUSB::RegHideFileExt(void)	设置文件名后缀隐藏
CUSB::RunHide(wchar_t *)	CreateProcess隐匿执行
CUSB::TraverseFolder(wchar_t *,int)	遍历特定文件目录
CUSB::USB2Disk(wchar_t ,wchar_t)	USB存储文件拷贝至PC主机
CUSB::USBFindFile(wchar_t *)	收集USB驱动设备上office类文件
CUSB::openexp(wchar_t *)	shell执行
export	Introduction

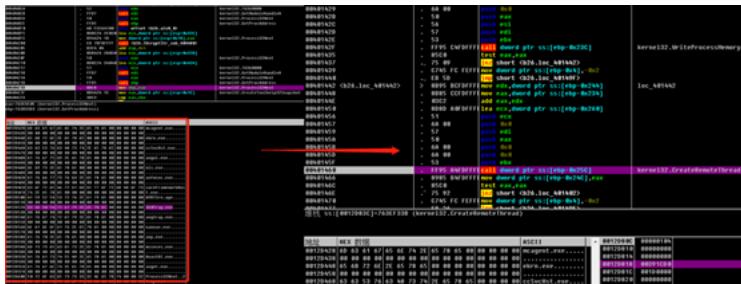
[illegible]

Stuxnet蠕虫通过PE文件资源段嵌入核心功能模块。

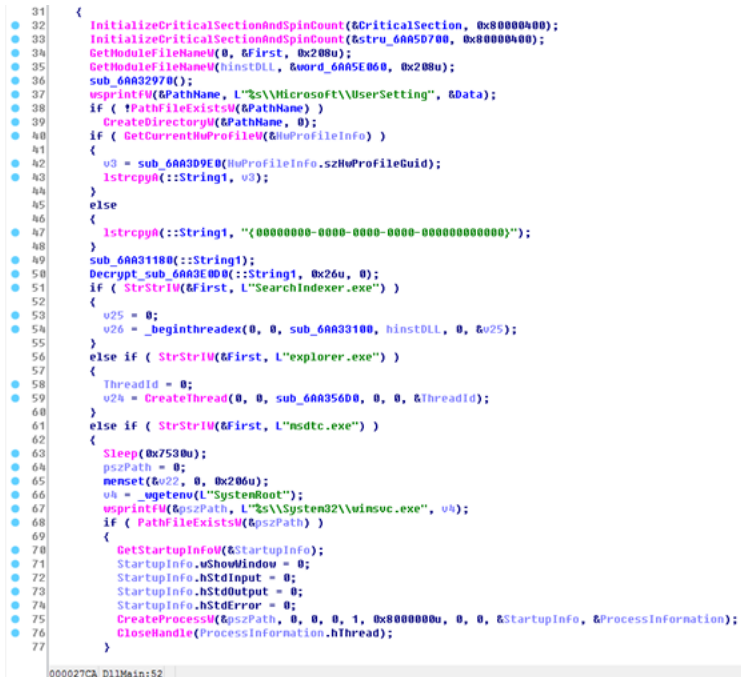


动态对抗杀软，主要存在两种方式：详尽的杀软检测然后选择退出或是特定的合法进程注入，白利用方式通过Dll加载路径劫持实现恶意Dll侧加载。

特定的进程注入如下所示。



涉及多个目标白利用程序的特定环境加载流程。



借助打包器中合法程序的安装过程UAC提权请求交互过程提升恶意模块运行权限。



4.3 USB摆渡

绝大多数蠕虫类病毒都具备对可移动存储设备的文件感染能力。对于隔离网络攻击事件而言, USB存储设备是可靠的或者也是唯一的一条侵入未知网络的途径, 基于USB设备的数据摆渡过程理所当然的成为了隔离网络攻击的关键环节。区别于普通蠕虫病毒的感染, 隔离网络攻击中的蠕虫模块基于其特定攻击目具有明显的个性化定制的特点。通过文件感染方式实现数据摆渡目的的同时, 蠕虫模块并不会影响原有文件的正常运行或显示, 非专业的恶意代码研究人员并不会觉察到文件异常。

作为数据摆渡的载体，该阶段的核心功能包括以下三点。

- 1、将攻击载荷带入目标网络。
- 2、将目标网络（隔离网络）中收集或窃取的敏感信息带出到互联网环境。
- 3、将C&C端下发的攻击指令（如果需要这种交互的话）带入到隔离网失陷主机，间接完成攻击者对隔离环境的控制。

我们从文件感染和数据交互两部分剖析该部分的恶意指纹。

4.3.1 文件感染

感染的目标文件类型主要为office文件、pdf文件、PE文件。对于文档类型的感染主要为相应的文档解析器的自动化漏洞急用工具生成。文件感染之前先收集移动磁盘文件信息，选择合适大小的文件进行感染。

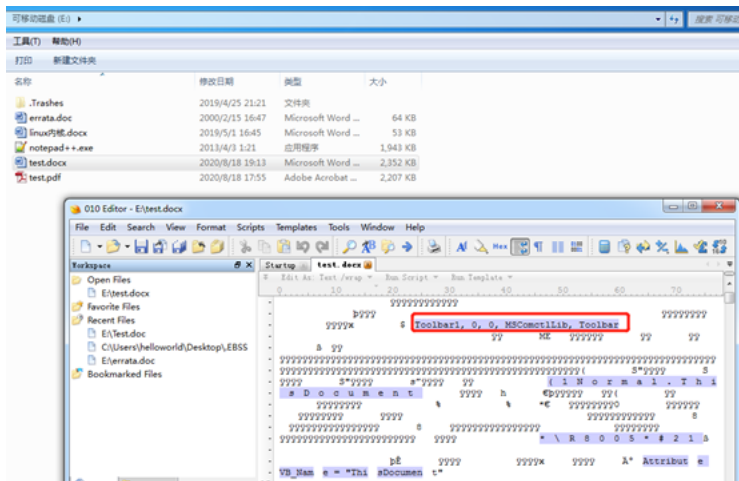
[illegible]

漏洞利用类型的感染逻辑为：以package对象形式嵌入PE模块（或加密二进制）资源，设置特定漏洞触发的结构数据。感染后的文档再次打开时将触发相应漏洞，通过特定的堆栈劫持链（针对栈溢出漏洞）控制加载释放的恶意模块。

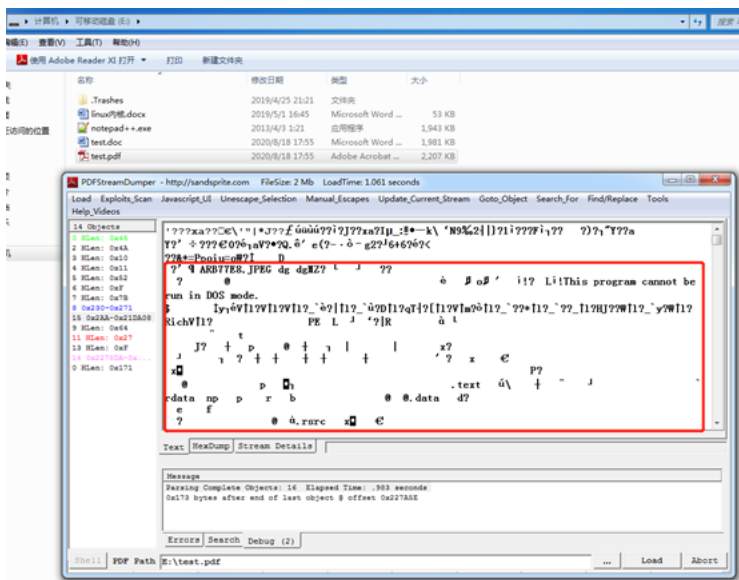
恶意模块数据写入文件如下所示。

```
1 // 注册表项名及值
2 #include <iostream>
3 #include <string>
4 #include <vector>
5 #include <map>
6 #include <algorithm>
7 #include <string.h>
8 #include <stdio.h>
9 #include <stdlib.h>
10 #include <time.h>
11 #include <windows.h>
12 #include <shlwapi.h>
13 #include <urlmon.h>
14 #include <ole32.h>
15 #include <oleaut32.h>
16 #include <advapi32.h>
17 #include <cryptui.h>
18 #include <cryptsp.h>
19 #include <cryptsp.h>
20 #include <cryptsp.h>
21 #include <cryptsp.h>
22 #include <cryptsp.h>
23 #include <cryptsp.h>
24 #include <cryptsp.h>
25 #include <cryptsp.h>
26 #include <cryptsp.h>
27 #include <cryptsp.h>
28 #include <cryptsp.h>
29 #include <cryptsp.h>
30 #include <cryptsp.h>
31 #include <cryptsp.h>
32 #include <cryptsp.h>
33 #include <cryptsp.h>
34 #include <cryptsp.h>
35 #include <cryptsp.h>
36 #include <cryptsp.h>
37 #include <cryptsp.h>
38 #include <cryptsp.h>
39 #include <cryptsp.h>
40 #include <cryptsp.h>
41 #include <cryptsp.h>
42 #include <cryptsp.h>
43 #include <cryptsp.h>
44 #include <cryptsp.h>
45 #include <cryptsp.h>
46 #include <cryptsp.h>
47 #include <cryptsp.h>
48 #include <cryptsp.h>
49 #include <cryptsp.h>
50 #include <cryptsp.h>
51 #include <cryptsp.h>
52 #include <cryptsp.h>
53 #include <cryptsp.h>
54 #include <cryptsp.h>
55 #include <cryptsp.h>
56 #include <cryptsp.h>
57 #include <cryptsp.h>
58 #include <cryptsp.h>
59 #include <cryptsp.h>
60 #include <cryptsp.h>
61 #include <cryptsp.h>
62 #include <cryptsp.h>
63 #include <cryptsp.h>
64 #include <cryptsp.h>
65 #include <cryptsp.h>
66 #include <cryptsp.h>
67 #include <cryptsp.h>
68 #include <cryptsp.h>
69 #include <cryptsp.h>
70 #include <cryptsp.h>
71 #include <cryptsp.h>
72 #include <cryptsp.h>
73 #include <cryptsp.h>
74 #include <cryptsp.h>
75 #include <cryptsp.h>
76 #include <cryptsp.h>
77 #include <cryptsp.h>
78 #include <cryptsp.h>
79 #include <cryptsp.h>
80 #include <cryptsp.h>
81 #include <cryptsp.h>
82 #include <cryptsp.h>
83 #include <cryptsp.h>
84 #include <cryptsp.h>
85 #include <cryptsp.h>
86 #include <cryptsp.h>
87 #include <cryptsp.h>
88 #include <cryptsp.h>
89 #include <cryptsp.h>
90 #include <cryptsp.h>
91 #include <cryptsp.h>
92 #include <cryptsp.h>
93 #include <cryptsp.h>
94 #include <cryptsp.h>
95 #include <cryptsp.h>
96 #include <cryptsp.h>
97 #include <cryptsp.h>
98 #include <cryptsp.h>
99 #include <cryptsp.h>
100 #include <cryptsp.h>
```

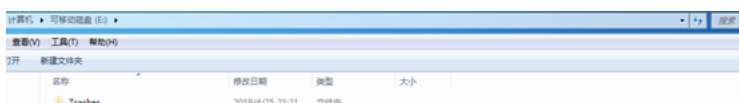
CVE-2012-0158 MSComctlLib.dll模块栈溢出漏洞利用感染后的效果如下所示。

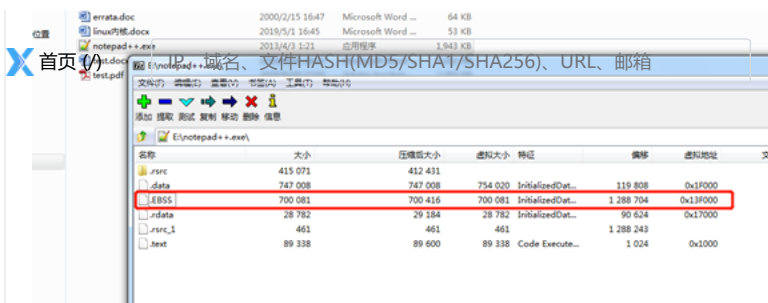


CVE-2010-2883 Adobe CoolType.dll模块栈溢出漏洞利用感染后的效果如下。



PE文件感染主要针对EXE可执行文件，常见感染方式包括创建新节区、资源段写入、自解压程序、代码段嵌入形式的打包器。

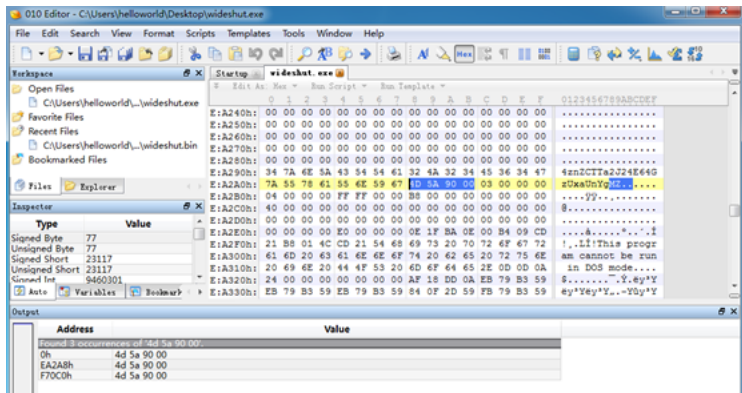




自解压类型的打包器感染。

名称	大小	压缩后大小	修改时间	属性	算法	固实	偏移	文件类
5PLUGINS.DIR	47 189	1 063 368						0
Lang	1 226 471	0						0
7-zip.chm	91 020	2010-11-1...		LZMA-22		+	1 211 910	
7-zip.dll	55 808	2010-11-1...		LZMA-22		+	3 444 157	
7z.dll	914 432	2010-11-1...		LZMA-22		+	1 302 934	
7z.exe	163 840	2010-11-1...		LZMA-22		+	505 334	
7z.sfx	162 816	2010-11-1...		LZMA-22		+	897 022	
7zCon.sfx	152 064	2010-11-1...		LZMA-22		+	1 059 842	
7zFM.exe	421 888	2010-11-1...		LZMA-22		+	83 442	
7zG.exe	227 840	2010-11-1...		LZMA-22		+	669 178	
description	333	2010-09-1...		LZMA-22		+	47 201	
History.txt	32 400	2010-11-1...		LZMA-22		+	47 538	
License.txt	1 927	2010-01-0...		LZMA-22		+	79 942	
readme.txt	1 565	2010-11-1...		LZMA-22		+	81 873	
Uninstall.exe				LZMA-22		+	3 499 969	

使用特定标记的rdata段感染。



除了以上提到的文件感染方式摆渡恶意载荷之外，在震网攻击事件中还使用了Lnk文件漏洞（CVE-2010-2568），该漏洞为Lnk文件解析漏洞，当PC机器总线接口驱动连接U盘设备时，文件管理器进程会自动解析U盘目录下的文件，恶意Lnk文件将会触发相应漏洞加载该目录下的Dll模块，恶意Dll模块随即会释放攻击载荷到PC机器。

4.3.2 数据交互

数据交互部分用于内网收集数据带出以及外网C&C下发数据带入两个流程。该部分一般通过文件数据追加方式实现。

通过特定标记提取可以移动磁盘介质中的数据如下所示。

```
52 | if ( !strcmp(&v0, ".docx") )
53 | {
54 |     if ( !strcmp(&v0, ".doc") )
55 |     {
56 |         if ( !strcmp(&v0, ".pdf") || !strcmp(&v0, ".zip") )
57 |         {
58 |             u5 = 0;
59 |             u4 = readfile_sub_6A83DAA0(&pszPath, &v5);
60 |             if ( u4 )
61 |             {
62 |                 if ( u5 > 100 )
63 |                 {
64 |                     GetFileExtendedOrder_sub_6A83DEA0(&pszPath, &v0, u4, v5);
65 |                     free(u4);
66 |                 }
67 |             }
68 |         }
69 |         else
70 |         {
71 |             u7 = 0;
72 |             u6 = readfile_sub_6A83DAA0(&pszPath, &v7);
73 |             if ( u6 )
74 |             {
75 |                 if ( !memcmp(u6, &v0, 8) && !memcmp(u6 + 512, &v0, 8) && u7 > 26000 )
76 |                 {
77 |                     GetFileExtendedOrder_sub_6A83DEA0(&pszPath, &v0, u6, u7);
78 |                     free(u6);
79 |                 }
80 |             }
81 |         }
82 |         else
83 |         {
84 |             u9 = 0;
85 |             u8 = readfile_sub_6A83DAA0(&pszPath, &v9);
86 |             if ( u8 )
87 |             {
88 |                 if ( !memcmp(u8, &v0, 8) && u9 > 12000 )
89 |                 {
90 |                     GetFileExtendedOrder_sub_6A83DEA0(&pszPath, &v0, u8, u9);
91 |                 }
92 |             }
93 |         }
94 |     }
95 | }
```



交互数据获取之后会删除该数据还原文件。

USBCulprit中的数据交互逻辑如下所示。



本篇报告较长，篇幅所限，本文仅为部分内容

扫描下方二维码，关注【微步在线研究响应中心】公众号

回复关键词“隔离网络”，可查看完整报告



微步在线

(http://

评论 7

发表评论



匿名用户

2020-11-12 11:17:08

回复

学习学习



匿名用户

2020-11-06 22:01:41

回复

学习 学习



匿名用户

2020-11-03 14:35:11

回复

努力学习学习



 (/nodev4/vb4/uCenter?userID=282b7ee2950f4e89a2a4dbcdeba7d237) 20200827121113
-10-29 16:41:50

2020
回复

在没有杀软的环境下，想想stuxnet是什么样的存在？就是百发百中。



 (/nodev4/vb4/uCenter?userID=d605baa0c1f842fcb61bf93f2b01faba) asdasdwq123
9 10:41:24

2020-10-2
回复

支持支持不错不错



匿名用户

2020-11-02 21:58:41

回复

回复@asdasdwq123: kanbudong



 (/nodev4/vb4/uCenter?userID=c98c210f687e413dbc2bbd135db6ca34) 24f1b76e9
10 15:16:22

2020-11-
回复

不错

p://
co
nn
ect.
qq.
co
m/
wid
ge
t/s
har
eq
q/i
nd
ex.
ht
ml?
url
=h
ttp
s%
3
A%
2
F%
2F
x.t
hre
atb
oo
k.c
n%
2F
no
de
v
4%
2Fv
b
4%
2Fa
rtic
l
e%
3Ft
hre
atl
nfo
l
D%
3D
30
00
&ti
tle
=%
E
3%
8
0%
9
0%
E
5%
B
E%
A
E%

IP、域名、文件HASH(MD5/SHA1/SHA256)、URL、邮箱

E
6%
A
D%
A
5%
E
5%
9
C%
A
8%
E
7%
B
A%
B
F%
E
6%
8
A%
A
5%
E
5%
9
1%
8
A%
E
3%
8
0%
9
1%
26l
dq
u
o%
3
B%
E
9%
9
A%
9
4%
E
7%
A
6%
B
B%
E
7%
B
D%
9
1%
E
7%
B
B%
9
C%
E
6%
9
4%
B
B%
E
5%

IP、域名、文件HASH(MD5/SHA1/SHA256)、URL、邮箱

8
7%
B
B%
26r
dq
u
o%
3
B%
E
4%
B
8%
9
3%
E
9%
A
2%
9
8% (htt
E p://
7% ser
A vic
0% e.w
9 eib
4% o.c
E o
7% m/
A sha
9% re/
B sha
6% re.
E ph
6% p?
8 url
A% =h
A ttp
5% s%
E 3
5% A%
9 2
1% F%
8 2F
A% x.t
20- hre
%2 atb
0% oo
E k.c
5% n%
B 2F
E% no
A de
E% v
E 4%
6% 2Fv
A b
D% 4%
A 2Fa
5% rtic
E l
5% e%
9 3Ft
C% hre
A atl
8% nfo
E l
7% D%
B 3D
A% 30
BF 00
X% &ti
- .

IP、域名、文件HASH(MD5/SHA1/SHA256)、URL、邮箱

E tie
6% =%
8 E
3% 3%
8 8
5% 0%
E 9
6% 0%
8 E
A% 5%
A B
5% E%
E A
7% E%
A E
4% 6%
B A
E% D%
E A
5% 5%
8 E
C% 5%
BA 9
&s C%
our A
ce 8%
=% E
E 7%
3% B
8 A%
0% B
9 F%
0% E
E 6%
5% 8
B A%
E% A
A 5%
E% E
E 5%
6% 9
A 1%
D% 8
A A%
5% E
E 3%
5% 8
9 0%
C% 9
A 1%
8% 26l
E dq
7% u
B o%
A% 3
B B%
F% E
E 9%
6% 9
8 A%
A% 9
A 4%
5% E
E 7%
5% A
9 6%
1% B
8 B%
A% E
E 7%
3% B
8 D%
0% 9
9 1%

1% E
E 7%
2% B
8 B%
0% 9
9 C%
C% E
E 6%
9% 9
9 4%
A% B
9 B%
4% E
E 5%
7% 8
A 7%
6% B
B B%
B% 26r
E dq
7% u
B o%
D% 3
9 B%
1% E
E 4%
7% B
B 8%
B% 9
9 3%
C% E
E 9%
6% A
9 2%
4% 9
B 8%
B% E
E 7%
5% A
8 0%
7% 9
B 4%
B% E
E 7%
2% A
8 9%
0% B
9 6%
D% E
E 6%
4% 8
B A%
8% A
9 5%
3% E
E 5%
9% 9
A 1%
2% 8
9 A%
8% 20-
E %2
7% 0%
A E
0% 5%
9 B
4% E%
E A
7% E%
A E
9% 6%
B A
6% D%
- .

IP、域名、文件HASH(MD5/SHA1/SHA256)、URL、邮箱

E A
6% 5%
8 E
A% 5%
A 9
5% C%
E A
5% 8%
9 E
1% 7%
8 B
A% A%
20- BF
%2 X%
0% E
E 6%
6% 8
8 3%
3% 8
8 5%
5% E
E 6%
6% 8
8 A%
A% A
A 5%
5% E
E 7%
8% A
A 4%
F% B
A E%
6% E
E 5%
6% 8
8 C%
3% BA
85 &p
&d ic=
esc htt
=& p
pic s%
s= 3
htt A%
p 2
s% F%
3 2F
A% x.t
2 hre
F% atb
2F oo
x.t k.c
hre n%
atb 2Fs
oo tati
k.c c%
n% 2Fi
2Fs m
tati g%
c% 2F2
2Fi d_c
m od
g% e.jp
2F2 g&
d_c ap
od pk
e.jp ey
g) =)

写下你的评论...

☐ 匿名

评论

 [首页 \(/\)](#)

IP、域名、文件HASH(MD5/SHA1/SHA256)、URL、邮箱